

AUTOMATIC UPDATE SYSTEM VULNERABILITY IN ASUS MAINBOARDS

Protecting your system software from
vulnerabilities effectively



HARITHIRAA YOGARAJ





THE RISK BEHIND ASUS's AUTO-UPDATE SYSTEM

- This article is about a recent security vulnerability that affected ASUS's automatic update system, specifically the Armoury crate and Driverhub tools.
- CVE-2025-3462
- CVE-2025-3463
- These two vulnerabilities allowed attackers to perform remote code execution at system level privileges by tricking the service into downloading and running malicious files from websites controlled by attackers.
- Both vulnerabilities were later officially patched by ASUS.





Software Affected

- ASUS DriverHub (Versions prior to 1.0.6.0)
 - A system utility responsible for handling firmware updates on ASUS desktop motherboards.
 - Contains the vulnerable components exploited in the CVEs.
- ASUS Armoury Crate (Versions prior to 6.1.13)
 - A unified tool used to control various ASUS features, including system lighting, cooling fans, and software updates.
 - Works alongside DriverHub on desktop systems, which increases the risk of being affected by the vulnerabilities.



Hardware Affected

- ASUS Motherboards (Only desktop variants)
 - The vulnerabilities specifically affect ASUS desktop motherboards, not laptops or other devices.
 - This is because only desktop motherboards rely on DriverHub for firmware updates.
 - Laptops and other ASUS devices use different update utilities that are not impacted.
- Product Distribution:
 - Used in desktop PCs with ASUS motherboards
 - DriverHub and Armoury Crate are commonly pre-installed or recommended for systems with ASUS motherboards.



Discovery

- This vulnerability was first discovered by MrBruh (Paul), a cybersecurity researcher.
- He found both vulnerabilities by chance, while testing the ASUS DriverHub.
- Curiosity led him to analyze these vulnerabilities deeper which then escalated to remote code execution capabilities.



Methods and Techniques Used:

- MrBruh used Proof-Of-Concept (PoC) involving a spoofed domain (driverhub.asus.com.mrbruh.com), a signed ASUS executable (AsusSetup.exe), and a modified .ini file to trigger remote code execution in DriverHub.
- After discovering the vulnerability, MrBruh created a script to monitor Certificate Transparency (CT) logs.
- The script looked for TLS certificates issued to domains like driverhub.asus.com.
- No suspicious certificates were found, indicating that the vulnerability had likely not been exploited in the wild.

Reporting Timeline:

07/04/2025 – Found the initial vulnerability

08/04/2025 – Escalated the vulnerability to RCE

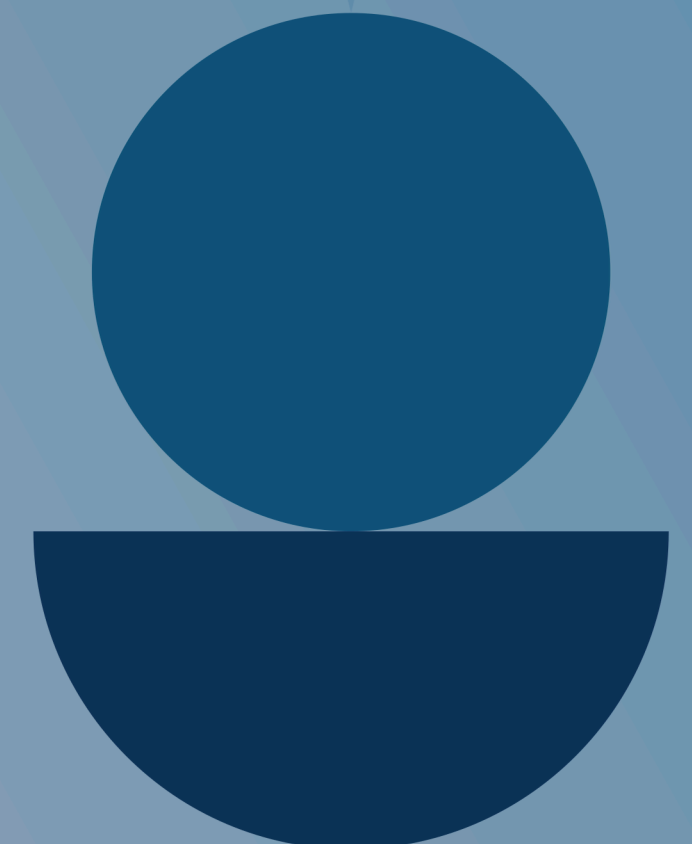
08/04/2025 – Reported the vulnerability

09/04/2025 – Automated response from ASUS

17/04/2025 – Followed up and got a human response letting him know they had patched the software and sent him a build to verify.

18/04/2025 – ASUS confirmed the fix was live

09/05/2025 – Patches for CVE-2025-3462 (8.4) and CVE-2025-3463 (9.4) were published.



CVE-2025-3462

- Origin Validation Error
- Allows attackers trick the software into accepting and processing requests from unauthorized websites by crafting malicious URLs.
- Severity - High
- CVSS Score - 8.4

CVE-2025-3463

- Improper Certificate Validation Error
- System could accept connections from untrusted sources which is extremely dangerous as it allows an attacker to run code remotely during the system's first-time setup, before any security tools or protections are in place.
- Severity - Critical
- CVSS Score - 9.4





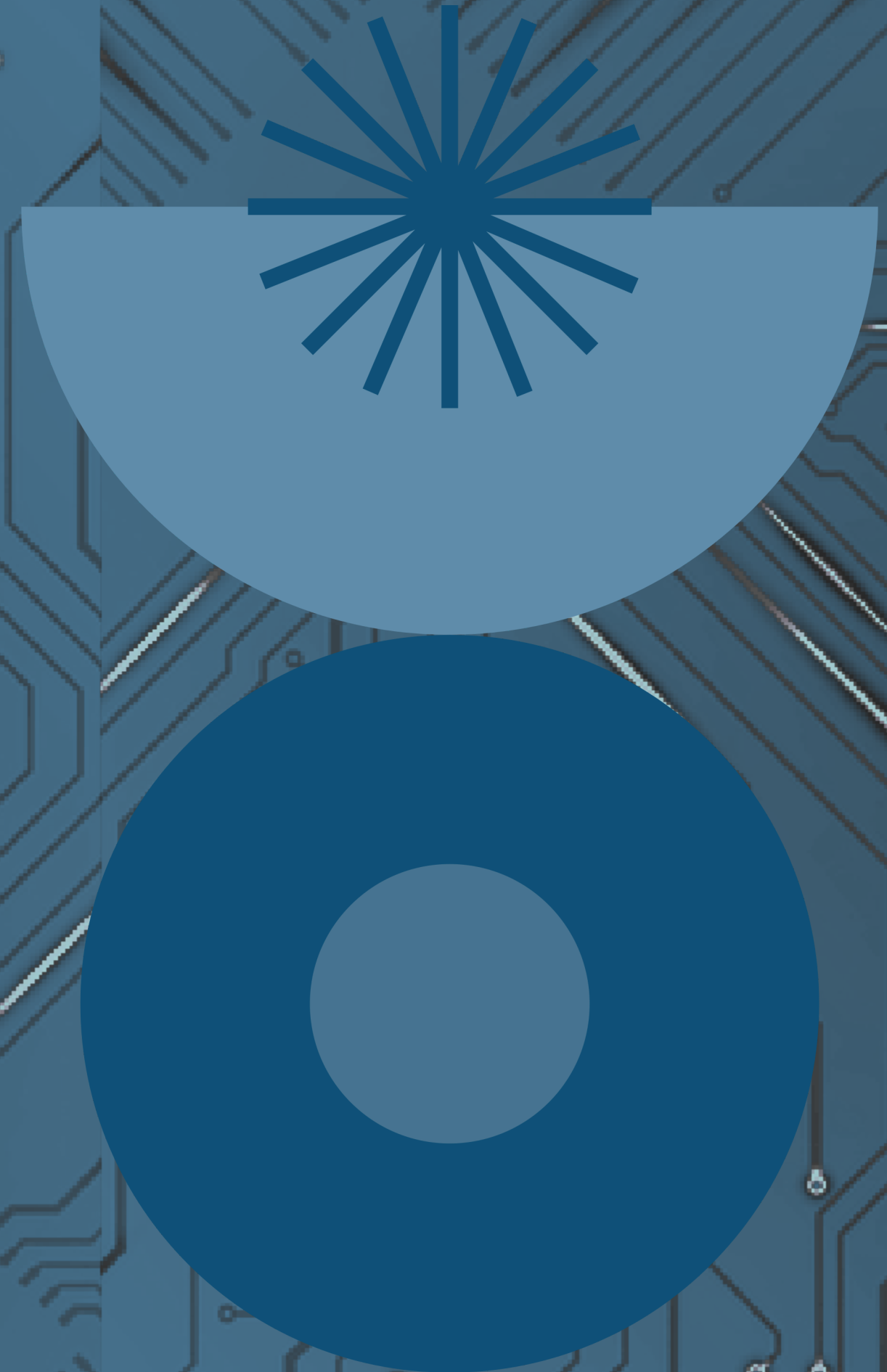
Necessary Conditions For Exploitation

- On the Victim's Side:
 - The system must have:
 - An ASUS motherboard
 - Armoury Crate version < 6.1.13
 - DriverHub version < 1.0.6.0
- The victim must visit a malicious website set up by the attacker.
- On the Attacker's Side:
 - Must host a malicious website with a subdomain that includes the string: "driverhub.asus.com" (e.g., driverhub.asus.com.mrbruh.com).
 - This tricks DriverHub's Origin validation logic (CVE-2025-3462).
- The attacker's server must host 3 malicious files:
 - A legitimate, signed AsusSetup.exe (downloaded from ASUS).
 - A malicious AsusSetup.ini that silently triggers the unauthorized file.
 - A malicious executable file that runs with system privileges.



Potential Consequences If Exploited

- These vulnerabilities, when exploited, can lead to remote code execution with SYSTEM-level privileges, without requiring any user consent.
- Since the attack is silent and fully automated once the user visits the malicious site, it could result in:
 - Complete control of the system, including the ability to install hidden malware
 - Theft of files, passwords, and access to private networks
 - Risk of spreading the attack to other systems through ASUS tools
- These consequences are difficult to detect because the attack uses legitimate signed programs and runs quietly in the background.





ZERO-CLICK VULNERABILITY IN ANDROID DEVICES

- A critical Android vulnerability (CVE-2025-27363) found in the Freetype image library which allowed attackers to exploit Pixel phones using a zero-click method—no user interaction needed. (CVSS score - 8.1-High)
- Malicious image messages could trigger remote code execution, giving hackers full control of the device.
- Exists in FreeType versions 2.13.0 and below (newer versions of FreeType are not vulnerable)
- Google patched this issue on May 5, 2025





COMPARATIVE ANALYSIS:

ASUS Update System vs. Android Zero-Click Exploit

Similarities:

- Both allowed Remote Code Execution (RCE)
 - ASUS: Exploited DriverHub & Armoury Crate to run malicious code with SYSTEM privileges.
 - Android: Zero-click exploit in Freetype allowed attackers to execute arbitrary code on affected Pixel devices, without any user interaction.
- Legitimate Software was used for both attacks
 - ASUS: Attack used a signed ASUS executable (AsusSetup.exe) to hide malicious actions.
 - Android: The exploit took advantage of a problem in a trusted system library (Freetype), which is used to display images and text, and was triggered by image messages.

Differences :

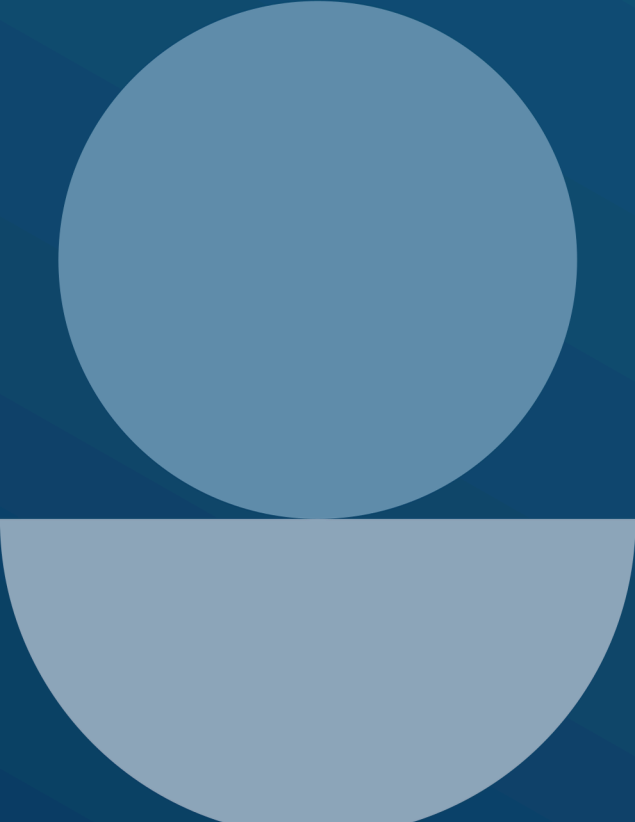
- Discovery Method
 - ASUS: Discovered by chance during manual testing by a cybersecurity researcher (MrBruh).
 - Android: Found through targeted security research by Meta's security researchers.
- User Interaction Requirements
 - ASUS: Required user to visit a malicious website created by the attacker.
 - Android: Zero-click-no user interaction needed. The attack used a malicious message to deliver the payload, making it harder to detect and more dangerous.
- Systems Impacted
 - ASUS: Only desktop ASUS motherboards using DriverHub and Armoury Crate.
 - Android - Android devices using FreeType versions up to 2.13, specifically those using Google Pixel phones with unpatched firmware.



Recommendations to Mitigate or Prevent Such Attacks

Technical Level:

- ASUS
 - Strengthen checks to verify website origins and secure certificate usage.
 - Restrict tools like DriverHub by isolating them to reduce their system permissions.
- Android
 - Improve security in native libraries (like Freetype) by adding stricter bounds-checking and memory protection.
 - Use safeguards to catch exploits during development.



Human Behaviour :

ASUS

- Update software regularly
 - Always keep Armoury Crate and DriverHub updated to the latest version.
 - Enable automatic updates if possible.
 - Download tools only from official ASUS sources
 - Avoid third-party or unofficial driver update tools, even if they look similar.
 - Be cautious about visiting unknown websites
 - The attack starts when users accidentally open a malicious website, so avoid clicking on suspicious links.
- 

Human Behaviour:

Android

- Install Android security updates as soon as they're available
 - These updates fix serious bugs.
- Use official messaging apps
 - Stick to apps like Google Messages that follow modern security standards and get regular updates.
- Avoid downloading unknown apps or media files
 - Don't download images, or messages from untrusted sources.



References For The First Article

- HeiseOnline.(2025,May13).Criticalsecurityvulnerability in automatic update system for Asus mainboards.
 - <https://www.heise.de/en/news/Critical-security-vulnerability-in-automatic-update-system-for-Asusmainboards-10380387.html>
- MrBruh. (2025, May 12). ASUS DriverHub RCE vulnerability analysis.
 - <https://mrbruh.com/asusdriverhub/>
- Tenable. (2025). ASUS DriverHub Remote Code Execution (CVE-2025-3462, CVE-2025-3463) – Nessus Plugin ID 237746.
 - <https://www.tenable.com/plugins/nessus/237746>
- SOCRadar. (2025, May 13). CVE-2025-3462 & CVE-2025-3463: ASUS DriverHub flaws.
 - <https://socradar.io/cve-2025-3462-cve-2025-3463-asus-driverhub-flaws/>
- ASUS. (2025). Product security advisory.
 - <https://www.asus.com/content/asus-product-security-advisory/>
- Feedly. (n.d.). CVE vulnerability feed.
 - <https://feedly.com/cve/>

References For The Second Article

- Google Urges Android Users to Update Devices Amid Zero-Click Vulnerability Exploits
Updated: 08/05/2025
 - <https://www.thescottishsun.co.uk/tech/14755693/google-android-pixel-phone-update-may-2025-attack/>
- Help Net Security. (2025, May 7). Actively exploited FreeType flaw fixed in Android (CVE-2025-27363).
 - <https://www.helpnetsecurity.com/2025/05/07/actively-exploited-freetype-flaw-fixed-in-android-cve-2025-27363/>
- Android Open Source Project. (2025, May 1). Android security bulletin—May 2025.
 - <https://source.android.com/docs/security/bulletin/2025-05-01>
- SOCRadar. (2025, May 6). Android's May 2025 update tackles CVE-2025-27363 & more
 - <https://socradar.io/androids-may-2025-update-tackles-cve-2025-27363-more/>
- Feedly. (n.d.). CVE vulnerability feed.
 - <https://feedly.com/cve/>

THANK
YOU!

